

SIMATS ENGINEERING

ASSESSMENT TOOL 3

Name	Abinеш M
Register Number	192465050
Date	
Time	1Hr

COURSE NAME: Cybersecurity Incident Handling And Response
COURSE CODE: CSA6001

COURSE OUTCOME COVERED

CO3: *Assess incident identification processes using monitoring systems, log analysis, threat intelligence, detection mechanisms to verify incidents, classify threats, assess their impact.*
(BL2, BL3)

Activity Tool : SIEM Alert Correlation and Incident Prioritization (Low)
Assessment Tool Weightage: 10%

Code of Conduct:

*I Abinеш M 192465050 (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
I understand that any violation of academic integrity rules will result in disciplinary action.*

Signature of the student:

Abinеш M
192465050

RUBRICS FOR CALCULATION:

Criteria	Weightage	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
SIEM Alert Analysis and Correlation	25%	Thoroughly analyzes multiple SIEM alerts and accurately correlates events based on time, user, IP address, host, and activity patterns to establish a clear incident sequence.	Analyzes and correlates most relevant alerts with minor gaps in identifying relationships.	Performs basic alert analysis but correlation is incomplete or misses important relationships.	Unable to analyze or meaningfully correlate SIEM alerts.
Incident Verification and Security Event Analysis	20%	Effectively verifies the incident using SIEM logs, IDS/IPS, EDR, authentication data, IOCs, and threat intelligence, clearly distinguishing related and unrelated events.	Verifies the incident using relevant security data with minor omissions.	Performs limited verification using a small number of security sources.	Unable to verify the incident or analyze supporting security evidence.
Incident Classification and Prioritization	25%	Accurately classifies and prioritizes incidents based on severity, asset criticality, affected users, data sensitivity, business impact, and likelihood of further damage, with strong justification.	Correctly classifies and prioritizes incidents with reasonable justification and minor gaps.	Provides basic classification and prioritization but considers limited factors or provides weak justification.	Incorrectly classifies or prioritizes incidents with little or no justification.
Anomaly and Behavioural Analysis	15%	Effectively identifies abnormal patterns and behavioural deviations and uses them to support incident correlation, severity assessment, and prioritization.	Identifies major anomalies and behavioural deviations with minor gaps in analysis.	Identifies basic anomalies but provides limited behavioural analysis.	Unable to identify or interpret significant anomalies or behavioural patterns.
Documentation, Analysis, and Presentation	15%	Provides clear, professional documentation with incident timeline, alert correlation, evidence, prioritization rationale, conclusions, and appropriate diagrams or workflows.	Documentation is well organized and understandable with minor analytical or presentation issues.	Documentation is partially organized with limited evidence or unclear analysis.	Documentation is incomplete, poorly organized, and lacks supporting evidence or clear conclusions.

SIEM Alert Correlation and Incident Prioritization

Question 1: SIEM Alert Correlation and Incident Prioritization

Receiving multiple, seemingly separate SIEM alerts — repeated failed logins, unusual network connections, privilege escalation, and suspicious process execution — is a common but critical situation in security operations. Individually, each alert might be low-to-medium severity and easy to dismiss as noise. Together, however, they can represent stages of a single, coordinated attack chain. My approach is to correlate the alerts into a unified timeline, verify that a real incident exists, assess its impact, and then prioritize the response based on risk to the organization.

1. Correlating the Alerts

- **Group by common entities:** Start by identifying shared identifiers across the alerts — the same source IP, username, hostname, or session ID — since alerts sharing an entity are the most likely to be part of one incident.
- **Sequence on a timeline:** Order the alerts chronologically to see whether they form a plausible attack progression, e.g., repeated failed logins → a successful login → privilege escalation → suspicious process execution → outbound connection. This sequence closely mirrors the standard attack lifecycle (initial access, privilege escalation, execution, command-and-control).
- **Apply correlation rules:** Use the SIEM's built-in or custom correlation rules (e.g., 'more than 5 failed logins followed by a success from the same source within 10 minutes') to automatically link related low-level events into a single higher-confidence alert.
- **Map to attacker behavior:** Reference the MITRE ATT&CK framework to confirm the sequence aligns with known tactics — Credential Access, Privilege Escalation, Execution, and Command and Control — which strengthens the case that this is a coordinated intrusion rather than coincidental unrelated events.
- **Cross-reference asset and user context:** Check whether the affected account has elevated privileges, whether the host is business-critical, and whether the activity deviates from that user's or host's normal baseline behavior.

2. Verifying the Incident

- Pull the raw logs behind each alert (not just the alert summary) to confirm the underlying event actually occurred as described and rule out sensor/logging errors.
- Validate the privilege escalation alert specifically — confirm whether a new admin-level token, group membership change, or exploited vulnerability was actually used, since this is often the strongest indicator of genuine compromise.
- Check the suspicious process against known-good software inventories and digital signatures to rule out an approved administrative tool or update process.

- Confirm the unusual network connection's destination against threat-intelligence feeds to determine whether it resolves to known-malicious infrastructure or a benign but unfamiliar service.
- Interview or check with the account owner (if applicable) to rule out legitimate but unusual activity, such as a scheduled maintenance window or a new administrative task.

3. Assessing Impact

Impact Dimension	Key Question	Why It Matters
Scope	How many accounts, hosts, or systems show related activity?	A single host is very different from lateral movement across many
Privilege level	Was the compromised account/process elevated to admin or domain rights?	Elevated access dramatically increases potential damage
Asset criticality	Are affected systems tied to critical business functions or sensitive data?	Determines business and regulatory exposure
Data exposure	Is there evidence of data access, staging, or exfiltration?	Drives breach-notification and legal obligations

4. Prioritizing the Response

Once verified, the incident is prioritized using a standard severity framework that weighs confirmed impact against business risk — typically combining the likelihood the activity is malicious with the potential damage if it is:

- **Critical/High** — Confirmed privilege escalation combined with active outbound communication to suspicious infrastructure on a business-critical system warrants immediate response: isolate the host, disable the account, and engage the full incident response process.
- **Medium** — Suspicious activity confirmed on a non-critical system with no evidence yet of privilege escalation or data access is investigated promptly but without full-scale containment, pending further evidence.
- **Low** — Alerts explained by legitimate activity (e.g., a password reset causing failed logins, or an approved software update triggering the process alert) are documented and closed, with tuning applied to reduce future false positives.

This tiered approach ensures the organization's limited response resources are directed first at the alert cluster most likely to represent a real, high-impact, active intrusion — rather than treating all four alert types as isolated, equally weighted events.

5. SIEM Tools and Techniques Supporting Correlation

- **Correlation rule engines:** Most SIEM platforms (Splunk ES, IBM QRadar, Microsoft Sentinel, Elastic Security) allow analysts to define multi-condition rules that fire only when a specific combination of event types occurs within a set time window, turning four separate low-severity alerts into one high-confidence composite incident.
- **Risk-based alerting (RBA):** Rather than treating every alert equally, risk-based alerting assigns a numeric risk score to each event and aggregates scores per user or host, so an account accumulating points from a failed-login burst, a privilege change, and a suspicious process crosses a threshold and is automatically escalated.
- **User and Entity Behavior Analytics (UEBA):** Machine-learning models baseline normal behavior per user and host, then flag deviations (unusual login time, atypical process, abnormal data movement) with a confidence score that can be combined with rule-based alerts for stronger evidence.
- **Case management / SOAR integration:** Once correlated, the composite incident is pushed into a case-management or SOAR (Security Orchestration, Automation and Response) platform, which can automatically enrich the case with threat-intel lookups and, where appropriate, trigger automated containment playbooks.
- **Dashboards and visualization:** Graph-based visualizations (attack-path or entity-relationship graphs) help analysts quickly see how the failed logins, privilege escalation, and process execution connect to the same account or host, speeding up manual verification.

6. Example Correlation Rule Logic

A representative correlation rule for this scenario might combine the four alert types into a single weighted condition, illustrating how raw events translate into an actionable, prioritized case:

Rule Condition	Logic	Resulting Action
Failed logins + success	5+ failures then 1 success, same source, within 10 minutes	Raise medium-severity 'possible credential compromise' alert
+ privilege escalation	Same account gains admin/group rights within 30 minutes of login	Escalate to high severity; auto-notify on-call analyst
+ suspicious process	Unsigned or LOLBin process launched from same host afterward	Escalate to critical; open incident case automatically
+ unusual network connection	Outbound connection from same host to low-reputation destination	Trigger SOAR playbook: isolate host, disable account, page IR team

This layered rule structure means the severity of the composite case increases automatically as more of the individual alerts link together on the same entity within the

time window — reflecting the increasing confidence that this is a genuine, active intrusion rather than four unrelated events.

Question 2: Correlation of Multiple Security Events

A suspicious login, an unusual IP connection, and an endpoint alert occurring within a short window is a textbook case for SIEM event correlation. The purpose of correlation here is to determine whether these three individually modest signals are actually three views of the same underlying incident, or three unrelated events that happen to be close in time.

1. What SIEM Correlation Does

A SIEM ingests logs from many disparate sources — identity providers, firewalls, endpoints, and applications — and normalizes them into a common format so that events which look unrelated in their raw form can be compared directly. Correlation engines then apply rules, statistical models, or both to determine whether multiple events are connected.

2. Correlation Techniques Applied to This Scenario

- **Entity-based correlation:** Check whether the suspicious login, the unusual IP connection, and the endpoint alert all reference the same username, source IP, or hostname. Shared entities are the strongest and simplest form of correlation evidence.
- **Temporal correlation:** Confirm the events occurred within a tight time window consistent with a single session — for example, the endpoint alert firing minutes after the suspicious login, rather than hours apart with no logical link.
- **Causal/sequence correlation:** Establish a plausible cause-and-effect order: a successful login from an unusual IP, followed shortly by an endpoint alert on the device the user authenticated from, suggests the login session itself led to the endpoint activity (e.g., malware execution or a malicious script).
- **Rule-based correlation:** Many SIEMs include pre-built rules such as 'login from new/unusual location AND endpoint alert on same host within 15 minutes' that automatically raise a single composite incident rather than three separate low-priority alerts.
- **Behavioral/statistical correlation (UEBA):** User and Entity Behavior Analytics compares the login's location, time, and device against the user's historical baseline, scoring the overall session as anomalous even if no single event alone would trigger a high-severity alert.

3. Working Through the Scenario

- Step 1: Confirm the suspicious login's details — source IP, geolocation, device, authentication method, and MFA status — and log the exact timestamp.
- Step 2: Check whether the unusual IP connection shares the same source IP as the login, or is a separate outbound connection made from the user's device after the login.

- Step 3: Pull the endpoint alert's host identifier and confirm it matches the device associated with the login session.
- Step 4: If all three share the same user/host identity and fall within a short time window, treat them as one correlated incident rather than three isolated alerts, and open a single case.
- Step 5: If entities or timing don't align (e.g., the endpoint alert is on a completely different, unrelated host with no shared user), investigate each independently, since forcing an unsupported correlation can waste response resources and mask the true, separate incident(s).

Example Correlated Timeline

A worked example illustrates how the three events might align on a single timeline to support a correlation decision:

Time	Event	Shared Entity
09:14	Suspicious login flagged: new country, valid credentials, MFA satisfied via push	user: jsmith; host: LAPTOP-22
09:16	Unusual outbound connection to a low-reputation IP on a non-standard port	host: LAPTOP-22 (same device)
09:19	Endpoint alert: unsigned process spawned by the browser, attempting registry write	host: LAPTOP-22 (same device)

Here, all three events share the same host within a five-minute window and follow a logical progression — login, outbound communication, then local malicious activity — giving high confidence that they represent a single compromise rather than three coincidental alerts.

4. Determining Whether the Events Are Related

The events are considered part of the same incident when correlation shows a consistent entity chain (same user or host) and a coherent timeline that mirrors a plausible attack narrative — for example: login from an unfamiliar IP → that same IP or session initiates an unusual outbound connection → the endpoint detects malicious process activity shortly after. This pattern is consistent with account compromise followed by malware execution or command-and-control communication on the affected device.

Conversely, if the shared entity is absent — for instance, the unusual IP connection originates from a completely different, unrelated user's device — the events are more likely coincidental or represent separate, smaller issues that should each be triaged on their own merits rather than escalated together. In either case, the correlation decision and supporting evidence are documented in the SIEM case record, and correlation rules are refined based on the outcome to improve detection accuracy for similar future event clusters.

5. Handling the Two Possible Conclusions

- **If correlated (same incident):** Open a single case covering all three events, assign it the severity of the most serious individual event (typically the endpoint alert if it indicates malware or unauthorized code execution), and begin containment — session/token revocation, host isolation if warranted, and password reset for the affected account.
- **If not correlated (separate events):** Triage each independently at its own severity: the suspicious login is investigated as a possible account-security issue, the unusual IP connection as a separate network anomaly, and the endpoint alert on its own merits — avoiding both under-reaction (dismissing a real separate incident because it didn't fit the narrative) and over-reaction (escalating unrelated benign events together).
- **Ongoing tuning:** Whichever outcome is reached, the specific entities and thresholds used in the correlation decision are fed back into the SIEM's correlation rules, gradually improving the tool's ability to automatically group truly related events and reducing analyst time spent on manual correlation for similar future clusters.

6. Why This Matters for Response Speed

Manual correlation of every alert cluster does not scale in a medium-sized organization generating hundreds or thousands of daily alerts. Automating entity- and time-based correlation directly in the SIEM — backed by UEBA scoring and clear escalation rules — is what allows a small security team to focus manual analyst time on the alert clusters most likely to represent genuine, connected incidents, rather than triaging every alert as an isolated event from scratch.

Conclusion

Both scenarios demonstrate that the real value of a SIEM lies not in individual alerts but in correlation — the ability to connect events across time, entities, and log sources into a single coherent narrative. Whether dealing with four distinct alert types across a broader environment or three closely timed events on a single user session, the analyst's task is the same: identify shared entities, establish a plausible timeline, validate the underlying evidence, and assess impact before committing response resources. This disciplined correlation process is what separates a security team that chases every individual alert from one that accurately identifies, prioritizes, and responds to the incidents that matter most.

Comparing the Two Scenarios

Aspect	Question 1: Multi-Alert Prioritization	Question 2: Short-Window Correlation
Scale	Four alert types, potentially across multiple hosts/accounts	Three events, focused on a single user/session
Main challenge	Assessing scope and business impact to prioritize response effort	Determining whether events are truly linked before acting

Aspect	Question 1: Multi-Alert Prioritization	Question 2: Short-Window Correlation
Key technique	Risk-based alerting and layered correlation rules	Entity- and time-based correlation, UEBA scoring
Decision output	Severity tier (Critical/High/Medium/Low) driving response urgency	Binary determination: single incident vs. separate unrelated events

In both cases, correlation quality directly determines response quality: under-correlating splits one real intrusion into several low-priority tickets that get deprioritized, while over-correlating wastes containment effort on unrelated benign activity. Continuously tuning correlation rules based on confirmed outcomes — in both directions — is what allows a SIEM program to mature over time and keep pace with an evolving threat landscape.